



INFORME PROFESIONAL DEL ANÁLISIS DE SEGURIDAD

CiberDojo - El arte de protegerte

AUDITORÍA ESTÁTICA	OWASP TOP 10	PLAN DE ACCIÓN
Código y arquitectura	Base 2021 + lectura 2025	Hoja de ruta 90 días

Fecha de emisión: 22 de septiembre de 2026

Fecha de corte técnico: 21 de septiembre de 2026

Repositorio: shield-ecuador-app | Commit: 41569fc

Índice

1. Resumen ejecutivo	4
Decisiones que requiere la dirección	4
Nota de interpretación	4
2. OWASP Top 10 explicado de forma sencilla	5
¿Para qué sirve OWASP Top 10?	5
Qué cambió en 2025	5
Ejemplo cotidiano	5
3. Alcance, método y nivel de confianza	6
Componentes revisados	6
Método aplicado	6
Qué NO cubrió la revisión	6
4. Postura de seguridad observada	7
Lectura correcta de las cifras	7
Fortalezas principales	7
5. Resultado detallado - OWASP Top 10:2021	8
6. Lectura de preparación - OWASP Top 10:2025	9
7. Hallazgos y riesgo residual	10
Hallazgos corregidos durante el ciclo	10
Riesgos altos ya corregidos antes del cierre	10
8. Cómo se protege CiberDojo: defensa en profundidad	11
Por qué RLS es importante	11
Por qué SRI es importante	11
9. Plan de acción priorizado	12
10. Indicadores de seguimiento	13
Criterios para declarar cierre	13

11. Conclusión profesional

Próximos tres pasos

1414

12. Fuentes y trazabilidad

Advertencias de uso

1515

Cómo leer este informe

El documento separa tres ideas: hallazgos (debilidades concretas observadas), cobertura OWASP (qué familias de riesgo están controladas) y alcance (qué no se probó). Esta distinción evita confundir una revisión de código con un pentest o con una certificación.

1. Resumen ejecutivo

CiberDojo presenta una postura de seguridad favorable en el código revisado. No se reportaron vulnerabilidades críticas ni altas en el producto de producción al cierre del ciclo. Los controles de acceso, autenticación, protección criptográfica, prevención de inyección e integridad de recursos están respaldados por evidencia técnica en el repositorio.

0	0	4	52/52
críticas abiertas	altas abiertas	pendientes actuales	tablas con RLS

Conclusión en una frase

El riesgo residual inmediato es moderado-bajo: la principal exposición pendiente está en la cadena de construcción del entorno de desarrollo, mientras que las demás brechas son operativas o documentales. Esta conclusión aplica únicamente al alcance estático revisado.

Decisiones que requiere la dirección

Decisión	Plazo sugerido	Resultado esperado
Autorizar prueba end-to-end del Centro de Seguridad	0-30 días	Confirmar que webhook y correo reciben alertas reales.
Modernizar o aislar el toolchain de frontend	30-90 días	Eliminar avisos heredados del entorno de desarrollo.
Formalizar threat model y retención de logs	30-60 días	Mejorar gobernanza, respuesta a incidentes y auditabilidad.
Programar pentest independiente	Después de remediar	Validar de forma dinámica lo que el análisis estático no puede demostrar.

Nota de interpretación

Los documentos fuente mencionan seis hallazgos. Al normalizar sus estados, seis fueron detectados durante el ciclo, dos quedaron corregidos y cuatro permanecen pendientes o aceptados: uno medio y tres bajos. Por ello, este informe no presenta los seis como vulnerabilidades activas.

2. OWASP Top 10 explicado de forma sencilla

OWASP es una comunidad internacional sin fines de lucro dedicada a mejorar la seguridad del software. Su Top 10 es un documento de concientización que agrupa las diez familias de riesgos más relevantes para las aplicaciones web. Explica cómo pueden presentarse esos riesgos, qué impacto podrían causar y qué controles ayudan a prevenirlos. [4]

¿Para qué sirve OWASP Top 10?

Una guía para priorizar la seguridad

OWASP Top 10 ayuda a desarrolladores, arquitectos, responsables de seguridad y directivos a reconocer riesgos comunes, ordenar acciones preventivas y revisar si una aplicación incorpora controles esenciales. No es una certificación automática: debe complementarse con análisis de riesgos, pruebas técnicas y seguimiento continuo.

Qué cambió en 2025

Cambio	Qué significa para CiberDojo
A01 incorpora SSRF	La evidencia de url-guard.ts pasa a reforzar Control de acceso roto.
A03 amplía componentes vulnerables a cadena de suministro	Los 29 avisos del toolchain requieren una lectura más amplia: dependencias, build y distribución.
A09 enfatiza alertas, no solo logs	La entrega real de webhook y correo se vuelve todavía más importante.
Nueva A10: manejo de condiciones excepcionales	Debe revisarse de forma enfocada el comportamiento ante fallos, límites, timeouts y estados anómalos.

Ejemplo cotidiano

Imagine un dojo con varias barreras: la recepción verifica quién entra, cada sala tiene permisos, los objetos valiosos se guardan bajo llave y una alarma avisa si algo ocurre. OWASP ayuda a comprobar que ninguna de esas barreras esenciales fue olvidada. Sin embargo, también hay que probar que la alarma suena y que el personal sabe responder.

3. Alcance, método y nivel de confianza

Componentes revisados

Componente	Tecnología / evidencia	Cobertura declarada
Aplicación de usuario	React + TypeScript	Entradas, autenticación, HTML, exportaciones y dependencias.
Consola administrativa	JavaScript / servidor propio	Login, cabeceras, reportes, gráficos y recursos CDN.
Backend	Supabase Edge Functions	Webhooks, IA, URLs externas, pagos y controles compartidos.
Base de datos	68 migraciones Supabase	RLS, roles, triggers, auditoría y progreso.
Pruebas	Jest + Playwright	85 pruebas Jest y cientos de pruebas Playwright citadas en los anexos.

Método aplicado

Paso	Técnica	Propósito
1	Lectura de código	Puntos de entrada, autenticación, archivos, llamadas externas y construcción de HTML.
2	Búsqueda de patrones	innerHTML, eval, funciones dinámicas, URLs sin validar y manejadores inseguros.
3	Dependencias	npm audit de producción y desarrollo.
4	Base de datos	Verificación de Row Level Security en las 52 tablas.
5	Validación	Pruebas automatizadas y revisión de correcciones del ciclo.

Qué NO cubrió la revisión

Límite esencial

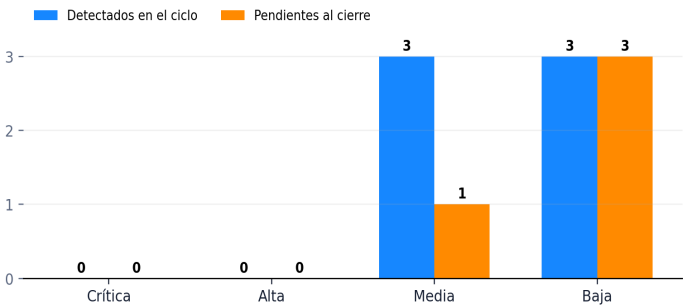
No hubo pentesting, fuzzing, escaneo de puertos ni explotación contra producción. Tampoco se auditó la configuración completa de Google Cloud Run, firewalls, IAM, proveedores externos o la entrega real de alertas. Por ello, el informe expresa evidencia favorable, no garantía absoluta de ausencia de vulnerabilidades.

4. Postura de seguridad observada

Evaluación original OWASP Top 10:2021



Hallazgos por severidad y estado



Lectura correcta de las cifras

Indicador	Resultado	Interpretación
OWASP 2021	7 completos / 3 parciales	Ninguna categoría quedó sin controles, pero “parcial” requiere trabajo adicional.
Hallazgos del ciclo	6	Tres medios y tres bajos fueron registrados durante la revisión.
Corregidos en el ciclo	2 medios	Exactitud de reportes y tolerancia a fallos de WebGL.
Pendientes al cierre	1 medio + 3 bajos	Toolchain, alertas E2E, guía de roles y threat model.
Críticos / altos abiertos	0 / 0	Dentro del código y alcance analizados.

Fortalezas principales

ACCESO	52 de 52 tablas con RLS; trigger que impide autoasignación de privilegios.
DATOS	Supabase Auth, Vault para claves y comparación resistente a temporización.
ENTRADAS	PostgREST parametrizado, escape de HTML y protección frente a fórmulas CSV.
RED	Bloqueo de IP privadas, HTTPS, redirecciones controladas y límite de respuesta contra SSRF.

5. Resultado detallado - OWASP Top 10:2021

Esta es la matriz formal utilizada por la auditoría original. “Cumple” significa que se encontró evidencia de controles relevantes; no equivale a certificación independiente.

ID	Categoría	Estado	Evidencia principal
A01	Control de acceso roto	Cumple	RLS en 52/52 tablas; trigger contra elevación de privilegios.
A02	Fallos criptográficos	Cumple	Supabase Auth, timingSafeEqual y secretos en Vault.
A03	Inyección	Cumple	PostgREST parametrizado, esc(), sin eval y csvSafe().
A04	Diseño inseguro	Parcial	Controles atómicos y datos sensibles no expuestos; falta threat model central.
A05	Configuración incorrecta	Cumple	CSP, HSTS, nosniff, Referrer-Policy, Permissions-Policy y SRI.
A06	Componentes vulnerables	Parcial	Producción: 0; desarrollo: 29 avisos, 14 altos.
A07	Identificación y autenticación	Cumple	Supabase Auth; bloqueo admin tras 10 intentos por 10 minutos.
A08	Integridad de software y datos	Cumple	Versiones CDN fijas, SRI y crossorigin.
A09	Registro y monitoreo	Parcial	Centro de Seguridad existe; entrega de alertas y retención no verificadas.
A10	SSRF	Cumple	url-guard.ts: IP privadas bloqueadas, HTTPS, redirecciones manuales y 512 KB.

Resultado base

Siete categorías con cumplimiento total y tres con cumplimiento parcial: A04, A06 y A09. La cifra del 70% comunica categorías totalmente satisfechas, pero no debe interpretarse como una puntuación matemática global de seguridad.

6. Lectura de preparación - OWASP Top 10:2025

La siguiente tabla actualiza el lenguaje y el orden de las categorías. Es un cruce razonado con la evidencia disponible, no una nueva auditoría integral. La edición 2025 incorporó dos categorías nuevas y una consolidación. [4][5]

ID 2025	Categoría vigente	Lectura CiberDojo	Base de la lectura
A01	Control de acceso roto	Evidencia favorable	RLS, trigger de roles y mitigación SSRF, ahora integrada en A01.
A02	Configuración incorrecta	Evidencia favorable	Cabeceras seguras y SRI; falta revisar infraestructura fuera del repositorio.
A03	Fallos de cadena de suministro	Parcial	Toolchain de desarrollo con 29 avisos; conviene SBOM y controles CI/CD.
A04	Fallos criptográficos	Evidencia favorable	Auth gestionada, Vault y comparación segura.
A05	Inyección	Evidencia favorable	Parametrización, escape y defensa CSV.
A06	Diseño inseguro	Parcial	Controles presentes; falta modelado de amenazas formal.
A07	Fallos de autenticación	Evidencia favorable	Supabase Auth y limitación de intentos en consola admin.
A08	Integridad de software o datos	Evidencia favorable	SRI y fijación de versiones.
A09	Registro y alertamiento	Parcial	No se confirmó entrega E2E ni política de retención.
A10	Manejo de condiciones excepcionales	Revisión focal requerida	Hay evidencia puntual de tolerancia a WebGL y timeouts, pero no evaluación completa.

Lectura ejecutiva 2025

Seis áreas muestran evidencia favorable, tres requieren fortalecimiento y una necesita una revisión focal nueva. No se recomienda trasladar automáticamente el “7 de 10” de 2021 a 2025 porque el contenido y el alcance de las categorías cambiaron.

7. Hallazgos y riesgo residual

Prioridad	Hallazgo	Riesgo / impacto	Estado y acción
Media	Toolchain de desarrollo: 29 avisos; 14 altos	Compromiso del entorno de desarrollo, servidor dev expuesto o deuda creciente. No se sirve al navegador final.	Pendiente. Actualizar react-scripts o migrar a Vite; aislar mientras tanto.
Baja	Entrega de alertas no verificada	Un incidente podría registrarse sin notificación efectiva al responsable.	Pendiente. Ejecutar prueba E2E controlada y conservar evidencia.
Baja	Cambio de rol vía SQL no documentado	Riesgo operativo: un DBA podría interpretar el bloqueo como error y debilitar controles.	Aceptado temporalmente. Crear procedimiento seguro con set_config.
Baja	Threat model disperso	Dependencia de conocimiento tácito; mayor probabilidad de regresiones de diseño.	Pendiente. Crear modelo de amenazas y registro de decisiones.

Hallazgos corregidos durante el ciclo

Componente	Problema original	Corrección verificada
Reportes administrativos	El límite de 5.000 filas podía distorsionar totales.	Conteo exacto independiente; el muestreo se informa.
Gráfico 3D	Sin WebGL, una excepción podía derribar gráfico y tabla.	Fallo aislado: se avisa y la tabla permanece disponible.

Riesgos altos ya corregidos antes del cierre

Los anexos señalan la corrección previa de XSS por HTML sin escapar, SSRF en webhooks y noticias, inyección de fórmulas CSV, acceso anónimo a funciones de pago y aprobación de análisis sin auditoría. Estas mejoras explican el buen estado actual, pero deben conservarse mediante pruebas de regresión.

8. Cómo se protege CiberDojo: defensa en profundidad

La seguridad no depende de una sola barrera. Los controles observados forman capas complementarias:

1. IDENTIDAD	Supabase Auth y bloqueo de intentos
2. AUTORIZACIÓN	RLS y trigger contra escalamiento
3. DATOS Y SECRETOS	Vault, HTTPS y comparación segura
4. ENTRADAS Y SALIDAS	Parametrización, escape, CSV seguro y url-guard
5. DETECCIÓN	Centro de Seguridad, logs y alertas

La capa que falta comprobar

El Centro de Seguridad está implementado, pero una alarma solo aporta valor si llega a una persona capaz de actuar. La prueba E2E de notificaciones es la acción de mayor retorno inmediato.

Por qué RLS es importante

Row Level Security aplica reglas directamente en la base de datos. Aunque una pantalla o una API se equivoque, la base puede seguir rechazando que un usuario lea o modifique filas ajenas. Verificar RLS en 52 de 52 tablas es una fortaleza significativa, pero las políticas concretas también deben probarse con roles positivos y negativos.

Por qué SRI es importante

Subresource Integrity permite que el navegador compruebe que un archivo cargado desde un CDN conserva el hash esperado. Si un tercero altera el recurso, el navegador lo rechaza. Este control reduce riesgo, pero no sustituye la gestión integral de la cadena de suministro.

9. Plan de acción priorizado



Reducción progresiva del riesgo residual

Acción	Responsable sugerido	Evidencia de cierre	Criterio de éxito
Probar alertas E2E	DevOps + Seguridad	Captura, evento, log y recepción	Webhook y correo llegan dentro del SLA definido.
Guía de cambio de roles	DBA / Backend	Runbook versionado	Cambio autorizado funciona; intento común queda bloqueado.
Threat model	Arquitectura + Producto	Diagrama, activos, amenazas y mitigaciones	Revisión aprobada y vinculada a cambios de alto riesgo.
Retención de logs	Seguridad + Legal	Política y configuración	Plazo, acceso, integridad y borrado definidos.
Modernizar toolchain	Frontend / DevOps	PR, lockfile y reporte npm audit	Sin avisos altos relevantes y build reproducible.
Evaluar A10:2025	AppSec / QA	Casos de fallos y resultados	Errores fallan de forma segura y no exponen datos.
Pentest independiente	Tercero autorizado	Informe y retest	Hallazgos críticos/altos corregidos o aceptados formalmente.

10. Indicadores de seguimiento

Para sostener la mejora, se recomienda presentar estos indicadores mensualmente al responsable de producto y trimestralmente a dirección:

Indicador	Meta	Frecuencia	Señal de alerta
Vulnerabilidades críticas/altas en producción	0 abiertas fuera del SLA	Continuo / mensual	Cualquier crítica o alta vencida.
Tiempo de entrega de alertas	Dentro del SLA definido	Prueba mensual	Alerta no recibida o sin trazabilidad.
Dependencias altas del toolchain	Tendencia a 0	Cada build / semanal	Aumento o dependencia sin responsable.
Cobertura RLS	100% de tablas aplicables	Cada migración	Tabla nueva sin RLS o política probada.
Pruebas de regresión de seguridad	100% verdes	Cada pull request	Control corregido vuelve a fallar.
Revisión del threat model	En cambios de alto riesgo	Por release	Nueva función sensible sin análisis.
Retención y acceso a logs	Según política	Trimestral	Eventos faltantes, alterables o inaccesibles.

Criterios para declarar cierre

No basta con...	El cierre exige...
“Se cambió el código”	Prueba reproducible, revisión y evidencia almacenada.
“La alerta está configurada”	Evento controlado recibido por el canal y destinatario correctos.
“npm audit bajó”	Analizar alcance, explotabilidad y dependencias transitivas.
“Existe RLS”	Políticas probadas como usuario autorizado, no autorizado y anónimo.

Recomendación de gobierno

Nombrar un dueño para cada riesgo, una fecha objetivo y una evidencia de cierre. Sin esos tres elementos, una recomendación suele permanecer abierta indefinidamente.

11. Conclusión profesional

La revisión muestra que CiberDojo ha avanzado desde la corrección de vulnerabilidades web relevantes hacia una etapa de madurez operativa y de gobernanza. Los controles técnicos más importantes están presentes en el código analizado, y los hallazgos de mayor impacto identificados durante ciclos anteriores fueron corregidos.

El próximo salto de calidad no depende únicamente de agregar más controles. Depende de demostrar que funcionan en condiciones reales: alertas que llegan, procedimientos que se siguen, dependencias que se mantienen, errores que fallan de forma segura y decisiones de arquitectura que quedan documentadas.

Dictamen de alcance

Con la evidencia disponible, la postura del código revisado es favorable y no presenta vulnerabilidades críticas o altas abiertas reportadas. Sin embargo, no corresponde afirmar que CiberDojo es “100% seguro” ni emitir una certificación: se requiere completar la remediación, una evaluación específica contra OWASP Top 10:2025 y un pentest autorizado independiente.

Próximos tres pasos

Paso	Cuándo	Acción
1	Esta semana	Ejecutar y documentar prueba E2E de alertas.
2	Este mes	Aprobar threat model, guía de roles y política de retención.
3	Este trimestre	Modernizar toolchain, revisar A10:2025 y contratar pentest con retest.

12. Fuentes y trazabilidad

Ref.	Fuente	Uso en este informe
[1]	Análisis de vulnerabilidades - CiberDojo	Documento adjunto. Revisión estática del commit 41569fc; hallazgos, estados y límites.
[2]	Cumplimiento OWASP Top 10 - CiberDojo	Documento adjunto. Matriz OWASP 2021 y evidencia por categoría.
[3]	Informe de Auditoría de Seguridad - CiberDojo	Documento adjunto. Resumen ejecutivo, controles y plan de acción.
[4]	OWASP Top 10:2025	https://top10.owasp.org/2025/ - edición oficial vigente, consultada el 22-09-2026.
[5]	OWASP Top 10:2025 - Introduction	https://top10.owasp.org/2025/0x00_2025-Introduction/ - cambios, metodología y categorías.
[6]	OWASP Top 10:2021	https://owasp.org/Top10/2021/ - base de comparación usada por la auditoría original.
[7]	A Comprehensive Review of OWASP Top 10 Web Application Security Vulnerabilities	Documento académico adjunto; marco conceptual general. Su análisis principal corresponde a OWASP 2021.

Advertencias de uso

Este documento reorganiza y explica la evidencia disponible. No sustituye los repositorios, logs, resultados de pruebas ni documentos técnicos originales. Toda decisión crítica debe validarse contra la versión exacta del código desplegado y su configuración de producción.

CiberDojo - El arte de protegerte

La seguridad es un proceso continuo: prevenir, detectar, responder, aprender y volver a probar.